

1 执行摘要

本文提出一种面向云原生环境权限提升类高危漏洞的防控框架，将大语言模型（LLM）生成过程中的随机性和不确定性控制在框架包含四个环节：检索增强的安全上下文构建提取非结构化漏洞信息，基于漏洞分析思维链的策略生成推导防控方案，为控制生成随机性与幻觉对输出的影响，该框架采取以下设计：

1. 将策略表示为结构化对象而非自然语言；
2. 所有证据片段均需附带来源标注；
3. 评价结论用于驱动后续改进迭代。

这些设计使得策略具有可追溯性、可复核性和可比较性。

为便于后续论述，本文将上述目标表述为如下问题：给定漏洞实例 v 及其可获得的安全上下文 c （带来源标注的证据片段 Π_v ，并通过评分与排序得到可交付策略及其质量证据（如 $s(\pi)$ 、 $q(\pi)$ 与 $R(\Pi_v, \dim)$ ）。

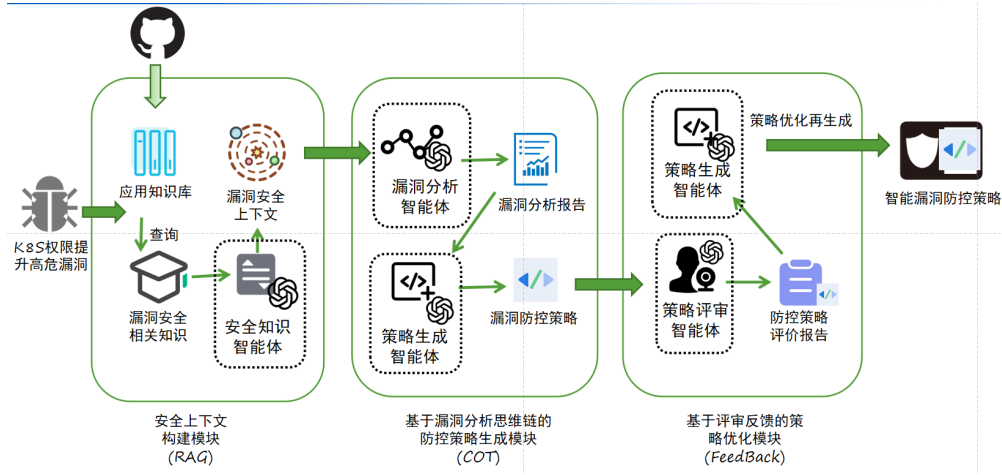


Figure 1: 框架流程示意，展示从上下文构建到策略生成与评价的主要步骤。

图?? 给出了方法的流程示意，便于理解各阶段输入输出的衔接关系。

2 背景与问题

云原生环境中第三方应用高危漏洞的治理面临两个核心挑战：补丁可用窗口与漏洞暴露窗口不匹配，需在补丁完善前提供可信 LLM 在文本理解与生成中表现出色，但其输出具有固有的随机性和幻觉风险，需要通过结构化约束机制来确保输出的可靠

3 形式化定义

3.1 基本对象

本节给出框架的形式化定义体系，用于精确刻画漏洞输入、策略生成与质量评价之间的关系。

定义 1（漏洞实例）：令 $\mathcal{V}$ 表示漏洞实例集合，每个漏洞 $v \in \mathcal{V}$ 由三元组表示：

$$v = \langle \text{id}, d, m \rangle$$

其中 id 为 CVE 标识符， d 为 CVE 公告或其他文本描述， m 为元数据（如严重性、受影响组件等）。

定义 2（安全上下文）：令 $\mathcal{C}$ 表示上下文集合，上下文 $c \in \mathcal{C}$ 是与漏洞 v 相关的证据性文本或结构化信息的集合。在本框架中，上下文构建强调”证据来源可标注”，可将上下文表达为：

$$c = \{(t_i, \text{src}_i)\}_{i=1}^n$$

其中 t_i 为片段内容， src_i 为来源标识（例如文档路径、公告链接等）。

定义 3（安全策略）：令 Π 表示安全策略空间，每个策略 $\pi \in \Pi$ 是一个结构化对象，至少包含目标、动作与约束三类要素。

$$\pi = \langle \text{goal}, \text{actions}, \text{constraints} \rangle$$

其中 goal 描述防控意图（例如缩小攻击面、降低可达性、增强检测）， actions 是可执行的控制措施集合（例如权限最小化、禁用高危接口）， constraints 描述可部署条件与业务边界（例如适用范围、风险与回滚条件）。

定义 4（策略产物）：令 $\mathcal{A}$ 为产物空间，产物 $a \in \mathcal{A}$ 表示策略在特定工具域中的具体载体（例如配置片段、规则定义、补丁脚本）。

3.2 评价与选择

本节给出”评分”与”排名”的形式化定义，以支持跨方法与跨模型的可比性分析。

定义 5（单策略评分函数）：定义评分函数 $s: \Pi \rightarrow [0, 1]$ ，用于刻画策略是否满足最低可用性阈值。在临时防控语境下，

定义 6（三维度质量向量）：定义质量向量 $q(\pi)$ 为三维向量：

$$q(\pi) = (E(\pi), I(\pi), D(\pi))$$

其中 E 为有效性（Effectiveness：覆盖攻击面/阻断关键路径）， I 为无干扰性（Interference：对业务的副作用与误报风险）， D 为可部署性（Deployability：语法与步骤清晰、可操作）。

定义 7（多策略排名）：对候选集合 $\Pi_v \subseteq \Pi$ ，定义排名算子 R 输出一个排列：

$$R(\Pi_v, \text{dim}) \rightarrow (\pi_{(1)}, \pi_{(2)}, \dots, \pi_{(k)})$$

其中 $\text{dim} \in \{E, I, D\}$ 表示评价维度， $\pi_{(1)}$ 为该维度最优候选。”最佳策略”存在多目标权衡时排名比单一分数更适合呈现策略偏好。

4 总体框架

该框架采用三阶段流程：

阶段1：知识库与上下文构建。以 CVE 描述与开源应用知识库为输入，通过检索增强与证据汇聚形成带来源标注的安全上下文 $c \in \mathcal{C}$ ，为后续推导提供可验证的信息基础。

阶段2：策略生成与优化。以安全上下文 c 与漏洞实例 v 为输入，通过结构化思维链推导防控方案，并通过评审反馈机制优化策略，输出候选策略集合 Π_v 。

阶段3：评价与质量控制。对候选策略进行结构化评价，输出门槛评分 $s(\pi)$ 、质量向量 $q(\pi)$ 和排名序列 $R(\Pi_v, \text{dim})$ ，用于筛选和排序可交付的策略。

5 知识库构建

知识库构建阶段的目标是将非结构化的漏洞描述转化为带来源标注的证据集合 $c = \{(t_i, \text{src}_i)\}_{i=1}^n$ ，通过爬虫拉取源代码、文档、公告等数据。数据来源与收集。本地部分遍历代码仓库收集可读文本文件（代码、配置、文档），过滤二进制内容；远程部分通过 GitHub API 获取 Issue（150 条）、PR（100 条）、Security Advisory（40 条），包含用户报告、补丁讨论和官方安全建议的信息。

智能分块策略。代码文件最大 160 行单块，遇到函数、类或注释时提前截断，块间保留 20 行重叠；文本与 Markdown 文件采用语义分块。去重与规模控制。计算块内容哈希值删除重复，过滤超长输入（单文件 > 2MB）防止内存溢出，通过 `-max-files` 参数（默认 1500）限制文件总数以平衡覆盖度与效率。

向量化与索引构建。采用 HuggingFace Embeddings（默认 `sentence-transformers/all-mpnet-base-v2`）进行语义编码，FAISS 索引加速检索。来源追踪与元数据保留。每个块保留元数据标签（来源文件路径、块 ID、块类型、大小、行数），检索结果附带元数据供溯源。

6 智能策略生成

6.1 方法概览

策略生成阶段的目标是从漏洞实例 v 和安全上下文 c 推导出候选策略集合 Π_v ，通过证据汇聚、策略推导和优化迭代三个相互协作的环节实现。

6.2 证据汇聚与上下文构建

该步骤从应用知识库和漏洞安全文献中检索与汇聚相关证据，设计原则包括：检索准确性采用多策略分层检索提高结果的准确性。

6.3 结构化策略推导

该步骤通过结构化推理将漏洞分析转化为防控策略，将隐式的推理过程显式化。推导基于流程约束和格式约束两层框架：流程约束（JSON 模式），明确字段与层级确保输出的结构一致性与可验证性。

策略对象建议以统一 schema 表达：

$\pi \equiv \text{strategy} = \{\text{cve_id}, \text{description}, \text{application}, \text{threat_analysis}, \text{risk_category}, \text{mitigation}\}$

其中：

- **threat_analysis** 对应威胁建模结果：
 - **preconditions**: 利用前置条件与关键假设；
 - **attack_path**: 攻击路径/关键步骤；
 - **blast_radius**: 影响面与潜在扩散范围。
- **mitigation** 对应控制选型与动作化结果：
 - **layer**: 控制域（权限/网络/运行时/审计检测等）；
 - **method**: 控制组合的摘要；
 - **action**: 可落地动作清单（部署步骤、验证方式、回滚边界）。

为确保策略的可执行性，引入硬约束条件：要求方案可在短时间内启动、涵盖至少两类防控手段、包含可验证的措施指标。候选策略集合 Π_v 的生成可采用多策略并行方法：对同一漏洞产生多个结构化策略对象，以探索不同的防控路径。由于所有策略遵循统一 schema 结构，它们可直接进入后续的评价与排名流程。

在交付前，生成结果需进行归一化处理：统一字段命名、补齐缺失字段、清理冗余信息，并在数据缺失处显式标注假设条件。

6.4 迭代优化与质检

该步骤通过独立评审和定向修订对候选策略进行质量控制。评审阶段对每个候选策略进行结构化检查，从有效性、干扰程度、可落地性等方面进行评估。

7 质量评价与筛选

该阶段对候选策略集合进行结构化评价，输出门槛评分 $s(\pi)$ 、多维质量向量 $q(\pi)$ 和策略排名 $R(\Pi_v, \text{dim})$ ，遵循“结构化输入-多维度评价-综合排名”流程。

7.1 门槛评分与质量评估

评分函数 $s: \Pi \rightarrow [0, 1]$ 用于判定策略是否满足最低可用性要求。该评分关注可部署性和风险降低效果。典型评价流程包括：明确评价指标。建立可核查的检查清单，包括：

- 完整性检查（关键字段是否齐全，信息缺失是否标注）
- 可部署性检查（是否给出具体步骤、验证方法和回滚边界）
- 一致性检查（策略与安全上下文的一致性，是否包含无依据的断言）
- 约束合规检查（是否符合临时防控的适用范围）

评分聚合。检查项结果通过加权和进行聚合：

$$s(\pi) = \text{clip} \left(\sum_{j=1}^m w_j \cdot r_j(\pi), 0, 1 \right)$$

其中 $r_j(\pi)$ 为第 j 项的评分， w_j 为权重。部分关键项可设置为硬约束，即任何关键项失败则整体评分低于阈值。流程控制。设定阈值 τ ，当 $s(\pi) < \tau$ 时策略转入反馈优化流程重新修订，当 $s(\pi) \geq \tau$ 时进入后续排名和筛选。质量向量。对通过门槛的策略，进一步用三维向量刻画其特性：

$$q(\pi) = (E(\pi), I(\pi), D(\pi))$$

其中：

- $E(\pi)$ ：有效性，即覆盖关键攻击路径和降低风险的程度
- $I(\pi)$ ：干扰程度，即对业务运营、误报风险和运维复杂度的影响
- $D(\pi)$ ：可部署性，即步骤清晰度、可操作性和验证回滚能力

每个维度通过可观测指标聚合为 $[0, 1]$ 分数，同时记录评分理由与证据来源。

7.2 多维排名

排名算子 $R(\Pi_v, \text{dim})$ 在指定维度上对候选策略进行排序：

$$R(\Pi_v, \text{dim}) \rightarrow (\pi_{(1)}, \pi_{(2)}, \dots, \pi_{(k)})$$

排名过程包括：

1. 过滤。移除评分低于阈值 τ 的候选，确保后续排名的策略均可部署。
2. 排序。按指定维度（有效性、干扰程度或可部署性）的评分降序排列。
3. 并列处理。当分数接近时，引入次级准则（如降低干扰程度作为次级准则）。
4. 结果说明。输出排名序列及每个策略的三维评分、关键优缺点和支撑证据。

7.3 评价驱动的迭代控制

评价结论决定策略是否可交付或需要进一步优化。当最高分候选仍低于阈值或关键维度存在缺陷时，评价报告转化为修订约束。

8 LLM 生成的可靠性保证

LLM的输出存在三类不确定性来源：生成随机性（同一提示可能产生不同输出）、输入不完整性（可用证据有限）和对约束的

1. 结构化表示。将策略表示为带明确字段的对象，而非自由文本，便于验证和比较。
2. 证据来源追踪。所有关键信息必须附带来源标识，支持结论的反向验证。
3. 过程透明化。将生成过程分为威胁分析和策略生成两个阶段，便于定位问题所在。
4. 量化评价。通过多维评分和排名将主观质量转化为可比较的指标。
5. 反馈迭代。评价结论用于驱动有针对性的改进，而非随机重新生成。

这些机制的组合使得策略交付质量不依赖于单次生成的正确性，而依赖于中间产物的可验证性和评价结论的可复核性。

9 评估与展示

框架的评估采用”过程可复现 + 证据可比对”的方式支持跨配置的结果比较，分三层组织：候选策略生成同一漏洞在不同方向上的攻击路径；展示维度基于三维质量向量 $q(\pi) = (E(\pi), I(\pi), D(\pi))$ ：有效性指策略对威胁的覆盖程度，干扰程度指对业务和运维的影响。

10 总结

本文提出了一个面向云原生权限提升漏洞的防控框架，将 LLM 的生成能力通过结构化约束和多阶段评价转化为可验证的防控措施。局限与展望：安全上下文的完整性和准确性直接影响后续分析，对知识库构建的质量提出了要求；评分权重和阈值需要根据实际场景进行动态调整。